



IT-SIMPLERA SOLUTION
Cyber Security Analyst Internship Program

WEEK 05 ASSIGNMENT REPORT

Network Enumeration, Service Discovery & Vulnerability Assessment

Prepared By: Muhammad Awais
Registration No: REDB01-0735
Role: Cyber Security Analyst Intern
Submitted To: Talal Rehan

Submission Date: 28/July/2026
Deadline: 31/July/2026, 11:59 PM

Table of Contents

Table of Contents	2
1. Introduction	3
2. Task 1 Network Enumeration	4
2.1 Nmap Commands Used	4
2.2 Scan Results & Evidence	4
2.3 Open Ports Summary	5
3. Task 2 Service Enumeration.....	8
4. Task 3 Vulnerability Research.....	10
5. Task 4 Scan Comparison	12
5.1 Comparison Table	12
5.2 Discussion	12
6. Task 5 Security Analysis & Remediation Recommendations	14
7. Task 6 Vulnerability Assessment Report.....	18
7.1 Scope.....	18
7.2 Tools Used	18
7.3 Enumeration Results	18
7.4 Vulnerability Findings.....	18
7.5 Recommendations	18
8. Challenges Faced	19
9. Conclusion	19
10. References.....	19

1. Introduction

This report documents the Week 05 assignment of the Cyber Security Analyst Internship Program at IT-Simplera Solution, supervised by Talal Rehan. Building on the reconnaissance and OSINT work completed in Week 04, this assignment focuses on network enumeration, service discovery, vulnerability research, and security analysis against an authorized practice target.

The purpose of this assignment is to simulate the enumeration phase of a real-world penetration test: identifying open ports and running services, mapping them to known CVEs, assessing associated risks, and recommending remediation and hardening measures. The work is organized into six tasks covering Nmap scanning, service enumeration, vulnerability research, scan comparison, security analysis, and the final assessment report.

Task 1 Network Enumeration

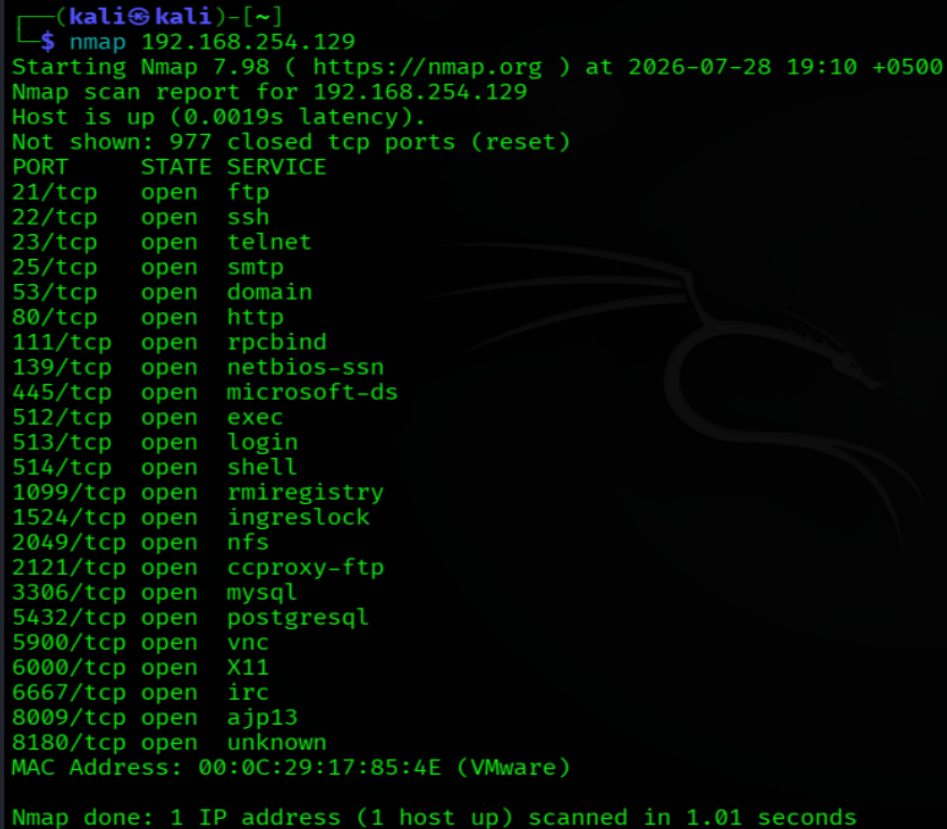
This task covers network scanning of the assigned lab target using multiple Nmap scan types, in order to identify open ports, services, and host details.

NOTE: Scans performed on Metasploitable2, intentionally vulnerable VM. Isolated lab environment

1.1 Nmap Commands Used

- `nmap <target>`
- `nmap -sV <target>`
- `nmap -O <target>`
- `nmap -A <target>`
- `nmap -p- <target>`

1.2 Scan Results & Evidence



```
(kali㉿kali)-[~]
$ nmap 192.168.254.129
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-28 19:10 +0500
Nmap scan report for 192.168.254.129
Host is up (0.0019s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:17:85:4E (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.01 seconds
```

`nmap <target>`

```

(kali㉿kali)-[~]
$ nmap -sV 192.168.254.129
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-28 19:15 +0500
Nmap scan report for 192.168.254.129
Host is up (0.0014s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:17:85:4E (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.66 seconds

```

`nmap -sV <target>`

```

(kali㉿kali)-[~]
$ nmap -O 192.168.254.129
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-28 19:18 +0500
Nmap scan report for 192.168.254.129
Host is up (0.0013s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:17:85:4E (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.36 seconds

```

`nmap -O <target>`

```

(kali@kali) [~]
$ nmap -A 192.168.254.129
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-28 19:20 +0500
Nmap scan report for 192.168.254.129
Host is up (0.0017s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp             vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_   Connected to 192.168.254.128
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh             OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet          Linux telnetd
25/tcp    open  smtp            Postfix smtpd
|_ssl-cert: Subject: commonName=ubuntu04-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_   SSL2_RC2_128_CBC_WITH_MD5
|_   SSL2_DES_64_CBC_WITH_MD5
|_   SSL2_RC4_128_WITH_MD5
|_   SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_   SSL2_DES_192_EDE3_CBC_WITH_MD5
|_   SSL2_RC4_128_EXPORT40_WITH_MD5
|_smtp-command: metasplitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITIME, DSN
|_ssl-date: 2026-07-28T14:20:29+00:00; 0s from scanner time.
53/tcp    open  domain          ISC BIND 9.4.2
|_dns-nsid:
|_bind.version: 9.4.2
80/tcp    open  http            Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
111/tcp   open  rpcbind         2 (RPC #100000)
|_rpcinfo:
|_   program version    port/proto  service
|_   100000 2 111/tcp     rpcbind
|_   100000 2 111/udp     rpcbind
|_   100021 1,3,4 45360/udp   nlockmgr
|_   100021 1,3,4 57059/tcp   nlockmgr
|_   100024 1 42338/udp   status
|_   100024 1 45509/tcp   status
113/tcp   open  netbios-ssn     Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn     Samba smbd 3.0.28-Debian (workgroup: WORKGROUP)
512/tcp   open  exec            netkit-rsh rshexecd
513/tcp   open  login           OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi        GNU Classpath grmiregistry
1524/tcp  open  bindshell       Metasploitable root shell
2049/tcp  open  nfs             2-4 (RPC #100003)
2121/tcp  open  ftp             ProFTPD 1.3.1
3306/tcp  open  mysql           MySQL 5.0.51a-3ubuntu5
|_mysql-info:
|_   Protocol: 10
|_   Version: 5.0.51a-3ubuntu5
|_   Thread ID: 9
|_   Capabilities flags: 43564
|_   Some Capabilities: Support41Auth, ConnectWithDatabase, SupportsTransactions, SwitchToSSLAfterHandshake, Speaks41ProtocolNew, SupportsCompression, LongCo
lumnFlag
|_   Status: Autocommit
|_   Salt: q4$5:0JmX1s166JR86=C
5432/tcp  open  postgresql      PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-date: 2026-07-28T14:20:29+00:00; 0s from scanner time.
|_ssl-cert: Subject: commonName=ubuntu04-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
5900/tcp  open  vnc             VNC (protocol 3.3)
|_vnc-info:
|_   Protocol version: 3.3
|_   Security types:
|_   VNC Authentication (2)
6000/tcp  open  x11             (access denied)
6667/tcp  open  irc             UnrealIRCd
|_irc-info:
|_   users: 1
|_   servers: 1
|_   lusers: 1
|_   lservers: 0
|_   server: irc.Metasploitable.LAN
|_   version: Unreal3.2.8.1. irc.Metasploitable.LAN
|_   uptime: 0 days, 0:11:47
|_   source ident: nmap
|_   source host: 2018B0BC.34A85110.FFFA6D49.IP
|_   error: Closing Link: cssylfhgz[192.168.254.128] (Quit: cssylfhgz)
8009/tcp  open  ajp13           Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp  open  http            Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Apache Tomcat/5.5
|_http-favicon: Apache Tomcat
|_http-server-header: Apache-Coyote/1.1
MAC Address: 00:0C:29:17:85:4E (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasplitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_clock-skew: mean: 59m59s, deviation: 2h00m00s, median: 0s
|_smb-os-discovery:
|_   OS: Unix (Samba 3.0.20-Debian)
|_   Computer name: metasplitable
|_   NetBIOS computer name:
|_   Domain name: localdomain
|_   FQDN: metasplitable.localdomain
|_   System time: 2026-07-28T10:20:20-04:00
|_smb2-time: Protocol negotiation failed (SMB2)
|_smb-security-mode:
|_   account used: guest
|_   authentication_level: user
|_   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

TRACEROUTE
HOP RTT ADDRESS
1 1.71 ms 192.168.254.129

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 23.20 seconds

```

nmap -A <target>

```

(kali㉿kali)-[~]
$ nmap -p- 192.168.254.129
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-28 19:26 +0500
Nmap scan report for 192.168.254.129
Host is up (0.0034s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
6697/tcp  open  ircs-u
8009/tcp  open  ajp13
8180/tcp  open  unknown
8787/tcp  open  msgsrvr
44772/tcp open  unknown
45509/tcp open  unknown
55319/tcp open  unknown
57059/tcp open  unknown
MAC Address: 00:0C:29:17:85:4E (VMware)

Nmap done: 1 IP address (1 host up) scanned in 11.59 seconds

```

`nmap -p- <target>`

1.3 Open Ports Summary

Port	Protocol	Service
21	TCP	FTP
22	TCP	SSH
23	TCP	Telnet
25	TCP	SMTP
53	TCP	DNS (Domain)
80	TCP	HTTP
111	TCP	RPCBind
139	TCP	NetBIOS-SSN
445	TCP	Microsoft-DS (SMB)
512	TCP	Exec (rexecd)
513	TCP	Login (rlogin)
514	TCP	Shell (rsh/tcpwrapped)
1099	TCP	Java RMI Registry
1524	TCP	Bind Shell
2049	TCP	NFS
2121	TCP	FTP (ProFTPD)
3306	TCP	MySQL

3632	TCP	DistCC
5432	TCP	PostgreSQL
5900	TCP	VNC
6000	TCP	X11
6667	TCP	IRC
6697	TCP	IRC over SSL (IRCS)
8009	TCP	AJP13 (Apache JServ Protocol)
8180	TCP	HTTP (Apache Tomcat)
8787	TCP	Msgsrvr
44772	TCP	Unknown
45509	TCP	Unknown
55319	TCP	Unknown
57059	TCP	Unknown

Task 2 Service Enumeration

Each service discovered during Task 1 is documented below with its version, status, and purpose.

Port	Protocol	Service Name	Service Version	Status	Purpose of Service
21	TCP	FTP	vsftpd 2.3.4	Open	File transfer between client and server.
22	TCP	SSH	OpenSSH 4.7p1 Debian 8ubuntu1	Open	Secure remote login and administration.
23	TCP	Telnet	Linux telnetd	Open	Unencrypted remote terminal access.
25	TCP	SMTP	Postfix smtpd	Open	Sending and relaying email messages.
53	TCP	DNS	ISC BIND 9.4.2	Open	Domain name resolution.
80	TCP	HTTP	Apache HTTP Server 2.2.8 (Ubuntu) DAV/2	Open	Hosts web applications and websites.
111	TCP	RPCBind	RPCBind v2	Open	Maps RPC services to network ports.
139	TCP	NetBIOS-SSN	Samba smbd 3.X-4.X	Open	Windows file and printer sharing.
445	TCP	SMB (Microsoft-DS)	Samba smbd 3.0.20-Debian	Open	Direct SMB file and printer sharing.
512	TCP	Exec	netkit-rsh rexecd	Open	Remote command execution.
513	TCP	Login	OpenBSD/Solaris rlogind	Open	Remote user login service.
514	TCP	Shell	tcpwrapped	Open	Remote shell (RSH) service.
1099	TCP	Java RMI Registry	GNU Classpath grmiregistry	Open	Java Remote Method Invocation registry.
1524	TCP	Bind Shell	Metasploitable root shell	Open	Backdoor root shell for remote access.

2049	TCP	NFS	NFS v2–v4	Open	Network File System for shared files.
2121	TCP	FTP	ProFTPD 1.3.1	Open	Alternative FTP file transfer service.
3306	TCP	MySQL	MySQL 5.0.51a-3ubuntu5	Open	MySQL database service.
3632	TCP	DistCC	DistCC	Open	Distributed C/C++ compilation service.
5432	TCP	PostgreSQL	PostgreSQL 8.3.0–8.3.7	Open	PostgreSQL database server.
5900	TCP	VNC	VNC Protocol 3.3	Open	Remote graphical desktop access.
6000	TCP	X11	X11 (Access Denied)	Open	X Window System graphical display service.
6667	TCP	IRC	UnrealIRCd 3.2.8.1	Open	Internet Relay Chat server.
6697	TCP	IRCS	Not Detected	Open	Secure IRC communication over SSL/TLS.
8009	TCP	AJP13	Apache JServ Protocol v1.3	Open	Communication between Apache and Tomcat.
8180	TCP	HTTP	Apache Tomcat/Coyote JSP Engine 1.1	Open	Tomcat web application server.
8787	TCP	Msgsrvr	Not Detected	Open	Messaging/server application (service not identified).
44772	TCP	Unknown	Not Detected	Open	Unknown service on a high-numbered port.
45509	TCP	Unknown	Not Detected	Open	Dynamic RPC-related service.
55319	TCP	Unknown	Not Detected	Open	Dynamic RPC-related service.
57059	TCP	Unknown	Not Detected	Open	Dynamic RPC-related service.

Task 3 Vulnerability Research

At least three services discovered during scanning are researched below for known vulnerabilities (CVEs).

	CVE ID	Vulnerability Name	CVSS Score	Severity	Short Description	Recommended Fix
1	CVE-2011-2523	vsftpd 2.3.4 Backdoor	9.8	Critical	Malicious backdoor allows remote command execution.	Upgrade to a patched version and disable vulnerable FTP service....
2	CVE-2008-2364	Apache HTTP Server mod_proxy_http Denial of Service	5.0	Medium	Apache HTTP Server 2.2.8 does not limit forwarded interim HTTP responses, allowing a malicious server to consume memory and cause a Denial-of-Service (DoS).	Upgrade Apache HTTP Server to a patched version (2.2.9 or later) and apply all available security updates.
3	CVE-2008-5161	OpenSSH CBC Mode Plaintext Recovery Vulnerability	3.7	Low	A weakness in OpenSSH 4.7p1 using CBC mode encryption may allow a remote attacker to recover portions of plaintext from an encrypted SSH session.	Upgrade OpenSSH to a patched version, disable CBC ciphers, and use stronger encryption algorithms such as AES-CTR or ChaCha20-Poly1305.

CVE-2011-2523 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

vsftpd 2.3.4 downloaded between 20110630 and 20110703 contains a backdoor which opens a shell on port 6200/tcp.

Metrics

CVSS Version 4.0CVSS Version 3.xCVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

 **NIST:** NVD

Base Score:
9.8 **CRITICAL**

Vector:
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

vsftpd 2.3.4

CVE-2008-2364 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

The ap_proxy_http_process_response function in mod_proxy_http.c in the mod_proxy module in the Apache HTTP Server 2.0.63 and 2.2.8 does not limit the number of forwarded interim responses, which allows remote HTTP servers to cause a denial of service (memory consumption) via a large number of interim responses.

Metrics

CVSS Version 4.0CVSS Version 3.xCVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 2.0 Severity and Vector Strings:

 **NIST:** NVD

Base Score: 5.0 **MEDIUM**

Vector: (AV:N/AC:L/Au:N/C:N/I:N/A:P)

Apache HTTP Server mod_proxy_http Denial

CVE-2008-5161 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

Error handling in the SSH protocol in (1) SSH Tectia Client and Server and Connector 4.0 through 4.4.11, 5.0 through 5.2.4, and 5.3 through 5.3.8; Client and Server and ConnectSecure 6.0 through 6.0.4; Server for Linux on IBM System z 6.0.4; Server for IBM z/OS 5.5.1 and earlier, 6.0.0, and 6.0.1; and Client 4.0-J through 4.3.3-J and 4.0-K through 4.3.10-K; and (2) OpenSSH 4.7p1 and possibly other versions, when using a block cipher algorithm in Cipher Block Chaining (CBC) mode, makes it easier for remote attackers to recover certain plaintext data from an arbitrary block of ciphertext in an SSH session via unknown vectors.

Evaluator Description

<http://securitytracker.com/alerts/2008/Nov/1021235.html> CBC mode connections are affected

Metrics

CVSS Version 4.0CVSS Version 3.xCVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

 **NIST:** NVD

Base Score: N/A

NVD assessment not yet provided.

ADP: CISA-ADP

Base Score: 3.7 **LOW**

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N

OpenSSH CBC Mode Plaintext Recovery Vuln

Task 4 Scan Comparison

This section compares the Nmap scans performed in Task 1.

4.1 Comparison Table

Scan Type	Speed	Information Discovered	Best Use Case
Nmap Version Detection (-sV)	Medium	Detects open ports, running services, and service versions (e.g., Apache 2.2.8, OpenSSH 4.7p1, MySQL 5.0.51a).	Identifying software versions for vulnerability assessment.
Nmap OS Detection (-O)	Fast	Identifies the target operating system, device type, and kernel version (Linux 2.6.9–2.6.33).	OS fingerprinting and network reconnaissance.
Nmap Aggressive Scan (-A)	Slow	Performs service/version detection, OS detection, NSE scripts, traceroute, and gathers detailed information such as HTTP titles, SMB details, FTP anonymous login, SSL certificates, and RPC services.	Comprehensive reconnaissance and penetration testing.
Nmap Full Port Scan (-p-)	Slowest	Scans all 65,535 TCP ports , discovering both common and uncommon open ports (e.g., 3632, 6697, 8787, 44772, 55319, 57059).	Finding all exposed services before a security assessment.

4.2 Discussion

Q1. Which scan was the fastest?

The **OS Detection scan (nmap -O)** was the fastest, completing in approximately **2.36 seconds**. It performs only operating system fingerprinting and basic port detection, making it quicker than the other scans.

Q2. Which scan discovered the most information?

The **Aggressive Scan (nmap -A)** discovered the most information. It identified:

- Open ports and service versions
- Operating system details
- HTTP titles and server headers
- FTP anonymous access
- SMB information
- SSL certificate details
- RPC services
- Traceroute results
- NSE (Nmap Scripting Engine) outputs

Q3. Which scan would you use in a real-world assessment, and why?

In a real-world security assessment, I would use the **Aggressive Scan (nmap -A)** because it provides comprehensive information about the target, including services, versions, operating system, and potential security weaknesses. This detailed information is valuable for vulnerability assessment and penetration testing.

Q4. What are the advantages and disadvantages of each scan?

Scan Type	Advantages	Disadvantages
-sV (Version Detection)	Identifies service versions for vulnerability analysis.	Does not detect OS or perform advanced enumeration.
-O (OS Detection)	Fast and accurately identifies the target operating system.	Provides limited information about services and applications.
-A (Aggressive Scan)	Provides detailed reconnaissance, including OS, versions, NSE scripts, and traceroute.	Slow, generates more network traffic, and is easier to detect by security monitoring systems.
-p- (Full Port Scan)	Scans all 65,535 TCP ports, including uncommon ports.	Takes the longest time and does not provide service version or OS information unless combined with other options.

Task 5 Security Analysis & Remediation Recommendations

For each open port and identified vulnerability, a detailed security assessment is provided, including attack scenario, risk level, remediation, and verification method.

Open Port/Service	Security Risk (purpose + why open)	Attack Scenario	Risk Level	Remediation	Verification	Reference
21/FTP vsftpd 2.3.4	FTP file transfer svc, open for file access. This version has known backdoor.	Attacker sends :) smiley in USER field → triggers backdoor → root shell on 6200/tcp.	Critical full unauthenticated RCE	1) Upgrade vsftpd to patched version 2) Disable anon login 3) Firewall FTP to trusted IPs only	Re-scan port 6200 after upgrade; confirm smiley trigger fails	NVD CVE-2011-2523
23/Telnet	Remote shell access, plaintext protocol.	Attacker sniffs network (MITM/ARP spoof) → captures creds in cleartext → logs in.	High no encryption, full account takeover	1) Disable telnetd 2) Replace with SSH 3) Block port 23 at firewall	Nmap scan shows port 23 closed/filtered; attempt telnet connect fails	NIST SP 800-53 SC-8 (transmission confidentiality)
512/513/514 rexec/rlogin/rsh	Legacy remote login trio, trust-based (.rhosts) auth.	Attacker spoofs trusted IP or abuses empty .rhosts → login without password.	High auth bypass via IP trust	1) Disable r-services 2) Remove .rhosts files 3) Enforce SSH-only remote access	Confirm ports 512-514 closed; rlogin attempts refused	CIS Benchmark – Disable legacy remote access services
1524/tcp bindshell/ingreslock	Leftover root shell bound to port, no auth (Metasploitable)	Attacker connects via nc <ip> 1524 → gets instant root shell.	Critical direct root access, zero auth	1) Kill/remove listening backdoor process 2) Firewall the port 3) Rebuild	nc connect attempt gets refused; port shows closed in nmap	OWASP – Insecure Default Configurations

	backdoor artifact).			host from clean image		
111/rpcbind + 2049/NFS	RPC portmapper + NFS file sharing.	Attacker runs showmount -e → finds world-exported share → mounts, reads/writes files without auth.	High sensitive file exposure	1) Restrict NFS exports to specific hosts 2) Disable rpcbind if unused 3) Use NFSv4 with Kerberos auth	Re-run showmount -e; exports show restricted/none	NIST SP 800-53 AC-3 (access enforcement)
139/445 Samba 3.X	SMB file/print sharing.	Attacker exploits username map script RCE (metasploit usermap_script) → root shell.	Critical unauthenticated RCE	1) Patch/upgrade Samba 2) Disable username map script option 3) Restrict SMB to internal VLAN + firewall	Metasploit module fails against patched host; smbclient anon access denied	CVE-2007-2447, CIS Samba hardening guide
3306/MySQL 5.0.51a	DB service, likely weak/blank root password.	Attacker connects with root/blank pw → dumps all DBs.	High full data compromise	1) Set strong root password 2) Bind MySQL to localhost/internal only 3) Remove test/anonymous accounts	Login attempt with blank pw rejected; mysql -u root from remote fails	CIS MySQL Benchmark
5432/PostgreSQL 8.3	DB service, old EOL version.	Attacker exploits known 8.3.x vuln or weak trust auth in	Medium outdated, patchable, requires added conditions	1) Upgrade PostgreSQL 2) Set pg_hba.conf to password/md5 auth	Version banner shows patched release; remote trust-auth login denied	NIST SP 800-53 SI-2 (flaw remediation)

		pg_hba.conf → DB access.		3) Firewall port to app servers only		
5900/VNC (protocol 3.3)	Remote desktop, weak VNC auth (obs. DES scheme).	Attacker brute-forces short VNC password → full GUI desktop control.	High full remote desktop takeover	1) Enforce strong VNC password / disable VNC 2) Tunnel VNC over SSH only 3) Restrict source IPs via firewall	Direct VNC connect from outside blocked; only SSH-tunneled access works	CIS Remote Access hardening guidelines
6000/X11	X Window display server.	Attacker connects to open X11 → captures keystrokes/ screen or injects input.	Medium info disclosure/session hijack, requires local network position	1) Disable X11 network listener (-nolisten tcp) 2) Firewall port 6000 3) Restrict to localhost only	xdpyinfo remote connect refused; port shows closed	CIS Unix/Linux hardening benchmark
6667/Unreal IRCd	IRC server, backdoored version.	Attacker sends crafted command after "AB" flag in source → executes arbitrary shell commands.	Critical unauthenticated RCE	1) Upgrade/replace UnrealIRCd 2) Verify binary checksum vs official source 3) Firewall IRC port from public access	Metasploit unreal_ircd_3281_backdoor module fails; binary hash matches official release	NVD CVE-2010-2075
8180/Tomcat (Coyote 1.1)	App server, manager interface likely	Attacker logs into /manager/html with default tomcat/tomcat	High RCE via app deployment	1) Change/remove default manager credentials	Login with default creds fails; manager app inaccessible externally	OWASP Top 10 – A07 Identification &

	default creds.	mcats → uploads malicious WAR → RCE.		2) Restrict manager app to localhost/admin IPs 3) Upgrade Tomcat version		Auth Failures
1099/Java-RMI	RMI registry service.	Attacker sends malicious serialized Java object to RMI registry → deserialization RCE.	High unauthenticated RCE via deserialization	1) Disable RMI registry if unused 2) Apply RMI deserialization patches 3) Firewall port 1099	Exploit module (java_rmi_server) fails; port closed to external scan	OWASP Top 10 – A08 Software/Data Integrity Failures
3632/distccd	Distributed compilation daemon.	Attacker sends crafted compile job to distccd → arbitrary command execution.	Critical unauthenticated RCE	1) Disable distccd (rarely needed in prod) 2) Restrict to trusted build-farm IPs 3) Firewall port 3632	distcc_exec exploit fails; port shows closed/filtered	CVE-2004-2687

Task 6 Vulnerability Assessment Report

This section functions as the final consolidated report, drawing on the findings from Tasks 1–5.

6.1 Scope

Assessment authorized against single lab target Metasploitable2 (IP 192.168.254.129), hosted on isolated VMware internal network, no other hosts/subnets in scope. Purely enumeration + vulnerability research no live exploitation performed. Assessment conducted from Kali Linux attack machine (192.168.254.128) within same isolated network segment.

6.2 Tools Used

- Nmap (port scanning, service/version/OS detection, NSE scripts)
- NVD / CVE Details (vulnerability lookup)

6.3 Enumeration Results

Full port scan (-p-) found 31 open TCP ports, far more than default top-1000 scans caught. Service/version scan identified outdated, EOL software across almost every port vsftpd 2.3.4, Samba 3.X, MySQL 5.0.51a, PostgreSQL 8.3, UnrealIRCd, Tomcat 5.5, distccd. OS fingerprinting confirmed old Linux kernel (2.6.9–2.6.33). Host clearly built as intentionally vulnerable target, not hardened at all.

6.4 Vulnerability Findings

13 findings documented, 4 rated Critical (vsftpd backdoor, Samba usermap_script RCE, ingreslock backdoor shell, UnrealIRCd backdoor, distccd RCE) all giving unauthenticated remote code execution. Remaining findings (Telnet, r-services, NFS, VNC, Tomcat manager, RMI) rated High/Medium, mostly due to weak/no authentication and plaintext protocols.

6.5 Recommendations

Priority 1: patch or remove backdoored services (vsftpd, UnrealIRCd, ingreslock, Samba). Priority 2: disable legacy plaintext protocols (Telnet, rlogin/rexec/rsh, X11 over network). Priority 3: enforce authentication hardening (MySQL root password, VNC strong auth, Tomcat manager creds). Priority 4: network-level controls firewall rules restricting exposed services to trusted hosts only.

Challenges Faced

- Initial confusion differentiating default top-1000 scan vs full -p- scan missed several non-standard ports (3632, 8787, 44772) until running full range scan.
- Mapping some services to exact CVEs took extra research since version banners (e.g. Samba "3.X - 4.X") weren't precise enough alone.
- Balancing scan depth vs realism running -A on every port would be noisy in a real engagement, had to reason through which scan order made sense.

Conclusion

This assignment gave hands-on practice with the enumeration phase of a pentest going from raw port scan to structured vulnerability findings to remediation advice. Working through Metasploitable2 showed clearly how outdated software and default configs stack up into a huge attack surface. Directly relevant to SOC analyst work too same instinct of "why is this port open, what's the risk" applies when triaging alerts or reviewing exposed assets in a real network. Good foundation for red team and blue team sides both.

References

- <https://nmap.org/docs.html>
- <https://nvd.nist.gov/>
- <https://owasp.org/www-project-top-ten/>
- <https://www.cvedetails.com/>
- <https://docs.rapid7.com/metasploit/metasploitable-2/>